

Informe Técnico de Pruebas de Penetración

Aplicación: OWASP Juice Shop

Autor: Bastian Landskron

Fecha: 24-06-2025

Objetivo

Realizar pruebas de penetración controladas sobre la aplicación vulnerable **OWASP Juice Shop**, con el fin de identificar al menos tres vulnerabilidades explotables, demostrar su impacto y proponer medidas de mitigación adecuadas basadas en buenas prácticas de seguridad.

Herramientas Utilizadas

Herramienta	Descripción	Enlace de descarga
OWASP ZAP	Escáner de seguridad para aplicaciones web	https://www.zaproxy.org/download/
Burp Suite	Interceptor y modificador de tráfico HTTP/HTTPS	https://portswigger.net/burp/communitydownload
Firefox	Navegador con soporte de proxy manual	https://www.mozilla.org/es-CL/firefox/windows/
OWASP Juice Shop	Aplicación web intencionalmente vulnerable	https://demo.owasp-juice.shop/#/search

Metodología

Paso 1: Acceso y Preparación

- Se accede a la instancia pública de OWASP Juice Shop:
<https://demo.owasp-juice.shop/#/search>
- Firefox fue configurado con un proxy manual (127.0.0.1:8080) para redirigir el tráfico a ZAP o Burp Suite según la herramienta utilizada.

Paso 2: Exploración Manual

Se navegó manualmente por las principales secciones:

- Página de inicio de sesión.
- Registro de usuario.
- Buscador de productos ([/#/search](#)).

Se identificaron los siguientes vectores de ataque:

Inyección SQL básica:

' OR 1=1 --

- Utilizada en el formulario de login para intentar evadir autenticación.

XSS reflejado en buscador:

Payload funcional 1 – Robo de cookies:

```
"><img src=x onerror="alert('Cookie: ' + document.cookie)">
```

Payload funcional 2 – Acceso a token JWT:

```
"><img src=x onerror="alert('Token: ' + localStorage.getItem('token'))">
```

-

Ambos payloads fueron ejecutados correctamente y desbloquearon el reto oficial **Cross-site scripting (XSS)** en Juice Shop.

Paso 3: Escaneo con OWASP ZAP

- Se utilizó ZAP como proxy y se ejecutó un escaneo activo.

Hallazgos principales:

- Endpoints con validación deficiente.
- Falta de cabeceras de seguridad (CSP, X-Frame-Options, etc.).
- XSS y CSRF detectados automáticamente.

Captura 1: Resultado del escaneo activo de ZAP.

Paso 4: Interceptación con Burp Suite

- Se ejecutó Burp Suite para interceptar tráfico durante acciones como login, edición de perfil y búsqueda.
- Se modificaron parámetros sensibles (`userId`, `role`, `email`) para intentar elevación de privilegios (`admin=true`).

Captura 2: Interceptación de token JWT y modificación manual.

Paso 5: Explotación de Vulnerabilidades

Vulnerabilidad	Descripción	Prueba exitosa	Impacto
XSS reflejado	Inyección en campo de búsqueda	✓	Robo de cookies y tokens
SQLi	Inyección en login	✓	Acceso sin credenciales válidas
CSRF	Petición externa para cambiar email	✓	Manipulación de cuenta

Captura 3: Ejecución de alert con `document.cookie`.

Captura 4: Visualización de JWT vía `localStorage.getItem('token')`.

Captura 5: Login exitoso con SQLi.

Captura 6: Ejecución de CSRF mediante formulario externo.

Paso 6: Mitigación y Recomendaciones

Vulnerabilidad	Medida de Mitigación
XSS	Escapar caracteres, aplicar sanitización del DOM, usar CSP.
SQLi	Consultas preparadas, validación estricta de inputs.
CSRF	Tokens CSRF únicos por sesión, verificación del origen (Referer).
JWT expuesto	Uso de cookies HttpOnly + Secure, evitar localStorage para tokens.

Recomendaciones adicionales:

- Activar autenticación multifactor (MFA).
- Aplicar un Web Application Firewall (WAF).
- Configurar correctamente las siguientes cabeceras:
 - `X-Content-Type-Options: nosniff`
 - `Content-Security-Policy: default-src 'self'`
 - `X-Frame-Options: DENY`

Conclusión

Durante las pruebas controladas se confirmaron al menos tres vulnerabilidades críticas (XSS, SQLi y CSRF) en OWASP Juice Shop. Se demostró que la aplicación permite ejecutar código JavaScript en el navegador del usuario, eludir mecanismos de autenticación y realizar acciones no autorizadas desde terceros.

El uso conjunto de herramientas como **OWASP ZAP**, **Burp Suite** y **Firefox** permitió realizar tanto pruebas automatizadas como manuales de forma efectiva, cumpliendo el objetivo del ejercicio.

Anexos

- Capturas de herramientas y payloads ejecutados.
- Logs de OWASP ZAP y Burp Suite.
- HTML del ataque CSRF.
- Reporte exportado en HTML/XML desde ZAP.
- Evidencia visual de las alertas ejecutadas por XSS.

